

Email Security: What We're Changing and Why

A one-page briefing for the superintendent and cabinet — the threat picture, what changes, what it costs staff, and what it prevents.

12

threats assessed

4

that stay high risk

5

asks of the cabinet

Email Security: What We're Changing and Why

For: Superintendent and Cabinet · From: Technology Department · Date: 2026-08-20

The situation

Criminals target school districts because we are large, public, and predictable. Our leadership names, titles, and email addresses are published on our own website. That is all someone needs to start.

Four things are happening to districts like ours right now:

Someone pretends to be a district leader. An email arrives with the superintendent's or a principal's name on it, asking a staff member to buy gift cards, approve a payment, or "handle something quickly and quietly." AI writing tools have removed the spelling mistakes that used to give these away.

Someone redirects a paycheck. A staff member is tricked into giving up their password. A few days later their direct deposit is quietly changed to a criminal's account. Nobody finds out until payday.

Someone poses as a vendor we already work with. A real vendor's email account is broken into. The criminal replies inside a real invoice conversation and changes the payment details. Everything looks legitimate because almost all of it is. **This is the most expensive category in K-12 — losses typically run into six figures.**

Someone steals a password even though we use a security code. New attack tools sit invisibly between the user and the real sign-in page. The user enters their password, enters their code, and everything works normally — but the criminal captures the session and walks in behind them.

Nationally, **82% of reporting school districts experienced a cyber incident** over an 18-month period. In the first half of this year alone there were **34 ransomware attacks** against American schools and colleges. Nearly all of it starts with email.

What we're doing about it

Stronger filtering on incoming mail. Messages impersonating a district leader are held for review rather than delivered. Risky attachments are opened in an isolated environment first. This is the single most effective change we're making, and staff will barely notice it.

Locking down our mass email lists. Today, one message can reach every employee at once. We're limiting who can send to district-wide lists, so a fake message from "the superintendent" reaches a handful of people instead of everyone.

A second step at sign-in for all staff. A password alone will no longer be enough.

Physical security keys for about thirty people — payroll, HR, finance, and technology administrators. These are the accounts that can move money or change everything, and a physical key is the only method that defeats the attack described above. **Cost: roughly \$1,500–3,000, one time.**

Approval before apps can connect to district accounts. A common trick is a fake app that asks for permission to read your email. Once granted, it keeps reading even after you change your password. We'll approve apps centrally, with a **10-school-day turnaround** for teacher requests.

Proving our own email is genuinely ours. We're publishing internet records so that messages faking our domain are rejected before they arrive anywhere. **This takes about three months and must be done carefully** — rushing it would stop legitimate messages to parents.

Tighter settings on student accounts. Outside adults will not be able to send files to students or chat with them through school accounts.

Knowing quickly when something gets through. Alerts routed to a monitored address, and the ability to remove a bad message from every inbox in the district within minutes.

What it costs users

CHANGE	WHAT PEOPLE NOTICE
Stronger filtering	Occasionally an expected attachment is delayed. Call the help desk
Second sign-in step	About three minutes to set up. A quick check at sign-in
Security keys (~30 staff)	A physical key on the keyring for finance and IT staff
App approval	Teachers request new apps instead of connecting them directly
Student restrictions	Students ask a teacher to share work outside the district
Email authentication	Nothing, if we do it correctly

Our commitment: if any of this interferes with teaching, we roll it back the same day and find another way. That rule is written into the plan.

What it prevents

- A fake message from a district leader reaching every employee at once
 - A staff paycheck being redirected without anyone noticing for a full pay cycle
 - A six-figure payment sent to a criminal in a real vendor conversation
 - A stolen password becoming access to student records and payroll
 - A break-in continuing after we thought we had fixed it
 - Outside adults contacting students through school-issued accounts
-
-

What this does not fix

We want to be straight about this rather than overstate it.

Three risks stay significant even after everything above, because no email setting can close them:

- 1. **Vendor invoice fraud.** When a real vendor's account is broken into, the message is genuinely from them. **The only reliable protection is a phone call to a number we had on file before the request.** That is a finance procedure, not a technology setting, and it needs the CFO's sign-off.
- 1. **QR codes.** A code on a flyer in a staff lounge never touches our email system at all. That is awareness, not configuration.
- 1. **Scams aimed at students directly** — particularly threats to share private images. These happen on apps we do not control, on personal phones, after hours. **What we can control is whether a frightened student believes they can tell an adult without getting in trouble.** That is a counseling and culture question, and it matters more than anything in this document.

Also outside this plan and needed separately: computer security software, network separation, and **tested offline backups** — the last of which is the only thing that reliably survives a ransomware attack.

What we need

- 1. **Endorsement of the plan**, so the technology department is not negotiating each change individually.
- 2. **Approval to purchase security keys** — roughly \$1,500–3,000, one time.
- 3. **A finance procedure requiring a phone callback** before any banking change, for payroll or vendors. **This single procedure prevents the most expensive incidents in this document, and it costs nothing.**
- 4. **Explicit permission for staff to slow down and verify** — including when the request appears to come from a district leader. This needs to be said out loud, by the superintendent, in writing. A payroll clerk who fears being criticized for questioning the superintendent will process the fraudulent change.
- 5. **Two 90-minute tabletop exercises per year** with the cabinet. Not technical — decisions. Who notifies parents, who talks to the press, when the board is told. Those are the questions that go badly in a real incident and they are free to practice.

Timeline

WHEN	WHAT	IMPACT
Weeks 1–2	Baseline, no changes	None
Weeks 3–5	Filtering, mass lists, admin accounts	Minimal — most of the benefit
Months 2–3	Second sign-in step, app approval	Noticeable, supported
Months 3–6	Email authentication	None if done carefully
Months 6–7	Student settings	Moderate, coordinated with instruction
Ongoing	Monitoring, training, exercises	—

The first month delivers most of the protection. Everything after that is either politically harder or technically slower, but the largest gains come early — and they start as soon as we have your endorsement.

Detail, sources, and step-by-step procedures: [this repository](#). Questions: [Technology Director](#).